Programa de Ciberseguridad

RETO 2: Sistema de Análisis de Configuración TLS y Riesgo de Exposición en Servicios Web

RESUMEN

La seguridad de las comunicaciones en internet depende en gran medida del uso correcto de protocolos criptográficos como TLS (Transport Layer Security), responsables de proteger la confidencialidad e integridad de los datos intercambiados entre usuarios, aplicaciones y servidores. Sin embargo, todavía es común encontrar servicios web que permiten versiones obsoletas del protocolo, suites criptográficas débiles o configuraciones inseguras que pueden facilitar ataques de interceptación, degradación criptográfica o manipulación del tráfico.

Para las organizaciones, este problema no es menor. Una mala configuración de TLS puede comprometer la seguridad de portales web, APIs, paneles administrativos y plataformas transaccionales, generando riesgos técnicos, regulatorios y reputacionales. No basta con "tener HTTPS"; es necesario validar si la configuración realmente cumple con criterios mínimos de seguridad.

El desafío propone que los participantes desarrollen una herramienta funcional capaz de analizar servidores web, identificar configuraciones TLS inseguras, clasificar hallazgos según criticidad y generar reportes claros con recomendaciones accionables de endurecimiento de seguridad.

OBJETIVO DEL RETO

Desarrollar en 8 horas un MVP (Producto Mínimo Viable) que permita analizar uno o varios servidores web, detectar configuraciones TLS inseguras y generar un reporte técnico comprensible que apoye la evaluación y mejora de la postura de seguridad de servicios expuestos a internet.

CONTEXTO DEL PROBLEMA

Las aplicaciones web, APIs y servicios digitales utilizan TLS para proteger la comunicación entre clientes y servidores. No obstante, en muchos entornos persisten configuraciones inseguras por razones como compatibilidad heredada, malas prácticas de despliegue, falta de monitoreo o ausencia de validaciones periódicas.

Entre los problemas más comunes se encuentran:

- Habilitación de versiones obsoletas del protocolo, como TLS 1.0 o TLS 1.1
- Exposición de configuraciones débiles o no recomendadas
- Falta de visibilidad centralizada sobre el estado de seguridad de múltiples dominios
- Ausencia de reportes claros para equipos técnicos o de gestión
- Dificultad para priorizar acciones de remediación

Las organizaciones necesitan herramientas que les permitan responder preguntas como:

- ¿Qué versiones de TLS están habilitadas en cada servidor?
- ¿Qué servicios siguen permitiendo configuraciones obsoletas o inseguras?
- ¿Cuáles hallazgos representan mayor criticidad?
- ¿Qué acciones deben ejecutarse para fortalecer la configuración?
- ¿Cómo comparar el nivel de exposición entre varios dominios o entornos?

La oportunidad consiste en construir una solución que convierta el análisis técnico de TLS en información útil, priorizada y accionable para la gestión de seguridad.

OBJETIVO ESPECÍFICO

Diseñar una solución end-to-end que integre cuatro componentes:

1. Ingreso y validación de objetivos

- Permitir el análisis de uno o varios dominios o direcciones IP.
- Validar que la entrada tenga formato correcto.
- Gestionar errores de conexión, puertos cerrados, timeouts o dominios no resolubles.
- Permitir análisis individuales o por lote.

2. Motor de análisis TLS

La solución debe ser capaz de identificar como mínimo:

- Versiones de TLS habilitadas
- Presencia de protocolos obsoletos
- Configuraciones inseguras o no recomendadas
- Estado general del servidor evaluado

Se valorará adicionalmente que detecte aspectos como:

- Versiones seguras recomendadas frente a versiones heredadas
- Presencia de puertos asociados al servicio analizado
- Inconsistencias entre servidores analizados
- Nivel de exposición relativo por host

- Clasificación de criticidad por hallazgo

3. Motor de evaluación y recomendaciones

La solución deberá interpretar los hallazgos y traducirlos en recomendaciones comprensibles, por ejemplo:

- Deshabilitar TLS 1.0 y TLS 1.1
- Restringir el servicio a versiones modernas del protocolo
- Revisar configuraciones heredadas por compatibilidad
- Priorizar remediación en servidores con mayor exposición
- Estandarizar configuraciones entre ambientes

No se evaluará únicamente la detección técnica, sino la capacidad de convertir resultados en recomendaciones útiles para seguridad.

4. Reporte o visualización de resultados

La solución deberá presentar resultados de forma clara, ya sea en consola, archivo estructurado o interfaz simple, mostrando como mínimo:

- Servidor analizado
- Versiones de TLS detectadas
- Hallazgos inseguros identificados
- Nivel de criticidad o severidad
- Recomendaciones específicas por servidor

Se valorará adicionalmente una vista consolidada que permita comparar varios servidores en una sola ejecución.

REQUISITOS TÉCNICOS

Lenguajes y frameworks permitidos

- Backend o scripting: **Python, Node.js o Bash**
- Interfaz opcional: **CLI, HTML simple, Streamlit o dashboard básico**
- Persistencia opcional: archivos planos en **JSON, CSV o HTML**

Herramientas y librerías sugeridas

Los equipos pueden utilizar herramientas como:

- **OpenSSL**
- **testssl.sh**
- **nmap**
- **sslscan**

También pueden apoyarse en librerías como:

- **socket**
- **ssl**
- **subprocess**
- **requests**, si lo requieren para validaciones auxiliares

Requisitos mínimos de implementación

- La herramienta debe analizar al menos un servidor de forma funcional.
- Debe identificar y reportar versiones TLS detectadas.
- Debe señalar configuraciones inseguras u obsoletas.
- Debe generar un resultado reproducible y entendible.
- Debe incluir instrucciones claras de uso.

Restricción del reto

El enfoque es **ciberseguridad defensiva y análisis de configuración**.

No se evaluarán capacidades ofensivas ni explotación de vulnerabilidades, sino la capacidad de diagnosticar configuraciones inseguras, priorizar riesgos y comunicar hallazgos con claridad.

RESULTADO ESPERADO

Una solución funcional que demuestre el flujo completo de análisis de configuración TLS:

1. Ingreso de un dominio, IP o lista de servidores.
2. Ejecución del análisis técnico sobre el objetivo definido.
3. Identificación de versiones TLS habilitadas.
4. Detección de configuraciones inseguras o heredadas.
5. Clasificación básica del riesgo por servidor.
6. Generación de un reporte con recomendaciones de remediación.
7. Presentación de 5 minutos con problema, enfoque, demo y hallazgos.

Ejemplo de salida esperada:

Servidor: api.example.com

TLS 1.0: ENABLED

TLS 1.1: ENABLED

TLS 1.2: ENABLED

TLS 1.3: DISABLED

Riesgo identificado: Exposición a protocolos obsoletos

Recomendación: Deshabilitar TLS 1.0 y TLS 1.1, y revisar compatibilidad para fortalecer el servicio con versiones modernas.

CRITERIOS DE ÉXITO

Criterio	Descripción
Funcionamiento end-to-end	La solución recibe objetivos, ejecuta el análisis, detecta riesgos y genera resultados claros.
Calidad del análisis técnico	La herramienta identifica correctamente configuraciones TLS inseguras u obsoletas.
Priorización del riesgo	Los hallazgos están clasificados o interpretados de forma útil para la toma de decisiones.
Claridad del reporte	Los resultados son comprensibles para perfiles técnicos y permiten actuar sobre ellos.
Estructura del código y documentación	Código limpio, organizado y con instrucciones claras de uso.
Presentación y storytelling	Explicación clara del problema, la solución y el valor de seguridad generado.

ENTREGABLES GENERALES

Herramienta desarrollada

Puede presentarse como:

- Script
- Aplicación web simple
- Notebook interactivo
- Herramienta de línea de comandos

Debe permitir ejecutar el análisis sobre uno o varios objetivos definidos por el equipo.

Reporte de seguridad

Debe incluir como mínimo:

- Servidores analizados
- Versiones de TLS detectadas
- Configuraciones inseguras identificadas
- Riesgos observados
- Recomendaciones de seguridad

Puede entregarse en alguno de estos formatos:

- Consola estructurada
- Archivo JSON
- Archivo CSV
- Reporte HTML simple
- PDF breve complementario

Notebook o script técnico

Debe contener el flujo completo del desarrollo:

1. **Ingreso y validación de objetivos**
    - Dominios, IPs o lista de servidores
    - Manejo de errores de entrada o conexión
2. **Análisis de configuración TLS**
    - Ejecución de pruebas
    - Identificación de protocolos habilitados

    - Registro de resultados por servidor
3. **Clasificación e interpretación**
    - Identificación de hallazgos inseguros
    - Asignación de criticidad o severidad
    - Recomendaciones de remediación
4. **Salida de resultados**
    - Exportación o visualización final
    - Comparación entre servidores, si aplica

Repositorio GitHub o carpeta ZIP organizada

Debe contener:

- Código fuente
- Documentación
- Instrucciones de uso
- Ejemplos de entrada y salida
- README con dependencias, pasos de ejecución y breve descripción del proyecto

RECOMENDACIONES

- Comiencen analizando un solo servidor antes de escalar a múltiples objetivos.
- Definan una estructura clara para clasificar la criticidad de los hallazgos.
- Generen mensajes de salida comprensibles, no solo resultados crudos de herramientas.
- Documenten el proceso de análisis y los supuestos utilizados.
- Validen los resultados con herramientas externas cuando sea posible.

- Prioricen una solución confiable, clara y explicable sobre una excesivamente compleja.

PITCH FINAL

Cada equipo presentará su solución en un espacio de 5 minutos, mostrando:

1. El problema de seguridad identificado
2. El enfoque técnico utilizado para el análisis
3. La herramienta desarrollada
4. Los resultados obtenidos en uno o varios servidores
5. Las recomendaciones de remediación
6. El valor de la solución para fortalecer la seguridad de servicios web